Policy 17 – Incident Response & Breach Notification

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Detection & Reporting

2.4 Incident Response Team & Roles

2.5 Containment & Eradication

2.6 Breach Notification & Communications

2.7 Post-Incident Review & Lessons Learned

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Ensure security and privacy incidents are identified, contained, reported, and resolved quickly, and that required notifications are issued on time.

2.2 Scope – All information assets, personnel, third-party services, and physical locations.

2.3 Detection & Reporting

- Security tools forward real-time alerts to an incident channel.
- Anyone discovering suspicious activity must report to security within one hour.
- Log every alert or report in the incident tracker with date/time.

2.4 Incident Response Team & Roles

- Assign Incident Commander, Technical Lead, Communications Lead, and Scribe; publish roster with 24 × 7 contacts.
- Maintain runbooks for malware, data breach, DDoS, and cloud compromise scenarios.

2.5 Containment & Eradication

- Isolate affected systems within 30 minutes of confirmation.
- Capture forensics where feasible; patch, clean, or rebuild before re-connect.
- Document actions and timestamps in tracker.

2.6 Breach Notification & Communications

- Notify management immediately for incidents involving personal or regulated data.
- Draft customer/regulator notices within legal time-frames (e.g., 72 h for personal-data breaches).
- Route all external statements through Communications Lead and legal counsel.

2.7 Post-Incident Review & Lessons Learned

- Conduct root-cause post-mortem within 10 business days.
- Record corrective actions, owners, and due dates; track to closure.

3. Policy Compliance

3.1 Measurement – Track mean time to detect (MTTD), mean time to contain (MTTC), and breach-notification deadlines; review quarterly.

3.2 Exceptions – Process deviations allowed only if required to protect life, safety, or critical systems; document afterward.

3.3 Non-Compliance – Unreported or mishandled incidents escalate to executive review; may trigger disciplinary action.

3.4 Continual Improvement – Update runbooks and tooling after each post-mortem or external audit finding.